Care Access Navigator

Compliance 1 — Task 3: Compliance Auditing Basics

Audit plan, evidence collection for three controls, compliance assessment with gap analysis, and remediation plan — executed against the live Care Access Navigator environment

Audit ID:	CAN-IA-2026-01
Prepared by:	Akhila Chennamaneni, GRC Analyst (auditor)
Auditee:	HealthLine Regional Medical Center — Care Access Navigator (CAN): Keycloak realm care-access-navigator, Microsoft Entra ID application, Azure subscription governance and monitoring
Criteria:	HIPAA Security Rule; PCI DSS v4.0.1 Req. 4, 7, 8, 10; CAN-POL-AC-001; CAN-PRC-AC-002
Fieldwork:	October 13, 2026 (evidence timestamps 17:47–17:49 UTC)

Audit opinion (summary)

Of the three controls tested, **encryption in transit (ENC-01)** is effective for Azure data services, with a documented lab exception for the identity provider. **Role-based access (AC-01)** is well designed — every workforce account holds exactly one role and every application receives only the roles it needs — but authentication settings fall short of policy and PCI DSS (no enforced MFA, brute-force protection off, 10-character passwords), and no completed access review exists yet. **Logging and alerting (LOG-01)** operated effectively during the period (50 alerts fired, including a detected incident), but a 12-month central log store no longer exists. Six findings were raised: **3 High, 2 Medium, 1 Low**.

1. Audit Plan

Element	Plan
Objective	Provide assurance that access to ePHI and the cardholder data environment is restricted to authorized, authenticated users, that security events are logged and alerted, and that data in transit is encrypted — as required by HIPAA, PCI DSS and HealthLine policy.
Compliance area	Identity, access and monitoring (technical safeguards)
In scope	Keycloak realm *care-access-navigator* (users, roles, client scopes, authentication settings); Entra ID enterprise application *care-access-navigator-keycloak-broker*; Azure Policy guardrails; Azure Monitor alert rules and alert history
Out of scope	Physical safeguards; application source code; the payment processor's environment (covered by its PCI Attestation of Compliance); clinical workflows
Criteria	HIPAA §164.308(a)(4), §164.312(a)(1), (b), (d), (e)(1); PCI DSS 4.2.1, 7.2.1–7.2.5, 8.3.4, 8.3.6, 8.3.7, 8.4.2, 10.2.1, 10.4.1, 10.5.1; policy CAN-POL-AC-001
Methodology	Risk-based approach aligned to IIA/ISACA audit standards: inquiry, inspection of system configuration, re-performance (validate-only policy tests), and computer-assisted extraction (kcadm.sh, Azure CLI, Microsoft Graph). Populations are small, so 100% of users and alert rules are tested (no sampling).

Element	Plan
Risk basis	Capstone risk register: excessive RBAC privileges, credential compromise and logging weakness were rated Critical/High inherent risk
Independence	Performed by the GRC Analyst, who also helped design some controls. This limitation is disclosed; in production the audit would be performed or reviewed by Internal Audit.

Timeline and resources

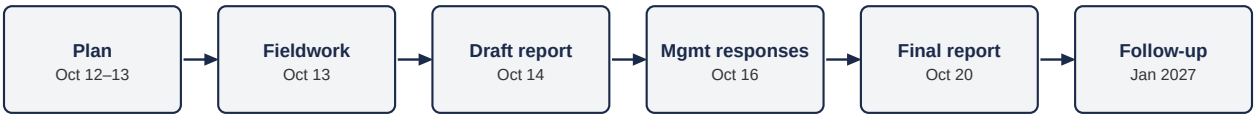

Figure 1. Audit timeline.

Resource	Allocation
People	GRC Analyst (lead, 12 h); IAM Analyst (walkthrough, 1 h); Security Officer (responses, 1 h)
Tools	Keycloak admin CLI (read-only), Azure CLI + Resource Graph, Microsoft Graph, shasum -a 256, validate-only ARM deployments (no resources created, no cost)
Access needed	Read-only Keycloak admin, Azure Reader at subscription, Entra directory read
Deliverables	Evidence pack with hash index; this report; remediation tracker entries

2. Evidence Collection

Evidence follows documented standards: each item has an ID, the control it supports, the evidence type, the collection technique, who collected it and when (UTC), and a SHA-256 hash recorded at collection so its integrity can be verified later. System-generated evidence is preferred over screenshots because it is complete and reproducible. Items are stored read-only in `compliance_1/audit-evidence/` with the hash index.

ID	Ctrl	Evidence	Type	Technique	Collected (UTC)
E-AC-01	AC-01	Keycloak users, realm roles, client role scopes, IdP role mappers	System extract	Inspection (CAAT)	2026-10-13 17:47
E-AC-02	AC-01	Keycloak authentication settings; Entra ID app assignments	System extract	Inspection (CAAT)	2026-10-13 17:48
E-LOG-01	LOG-01	Alert rules, action group, 30-day alert history, log-store status	System extract	Inspection + inquiry	2026-10-13 17:48
E-ENC-01	ENC-01	Policy assignment and 3 validate-only deployment tests; IdP transport	Test result	Re-performance	2026-10-13 17:49
tpl-*.json	ENC-01	Test templates used for re-performance	Supporting	—	2026-10-13 17:49

Integrity record (SHA-256)

audit-evidence/EVIDENCE-INDEX-SHA256.txt

```
E-AC-01_keycloak_users_roles.txt
    2c94fabfceacd3d058be40bc48ef244f72e9cc218c5826a955f596de522722c1
E-AC-02_authn_settings_and_entra_assignments.txt
    eec9ece839fcd29226eef5c7f07343d0873457cdd726aefb5bff71036eb3488f
E-ENC-01_tls_enforcement.txt
    2dda385fbcbb32909e5224ccefa8505c617bb346a64f92f45561a0fee09cf668
E-LOG-01_alerting_and_log_retention.txt
    0063a1a5ac8512a10f02f2a3ff109a8f1341adec43d75db22b5fe9d6ea103dc3
tpl-http.json
    8b114dea7f87a51f1ef7ff76d8e0b95bf8a72a165648b7bdc1cc5ae2ce356c70
tpl-ok.json
    a613a68c745029d5cc7cabbc7cff2a18e3b812e62efa748aca987abc1eb35480
tpl-tls10.json
    6b7d76b0692fef6fd3ffeef9e62ac058cc9d57ccb7463ac386bc6427de021643
```

Chain of custody: collected by the GRC Analyst directly from the source systems via authenticated read-only sessions; written straight to the evidence folder; hashed within one minute; no manual editing. Any later change to a file changes its hash and invalidates the item.

3. Compliance Assessment

Each control was tested for **design effectiveness** (is the control capable of meeting the requirement?) and **operating effectiveness** (did it actually work during the period?).

AC-01 Role-based access control and access review

#	Test performed	Expected	Actual (evidence)	Result
1	Inspect all 10 Keycloak accounts and their realm roles	Each user has only the role for their job	All 9 workforce test accounts hold exactly one role matching their function; the administrator's federated account holds no application role (E-AC-01)	**PASS**
2	Inspect application client role scopes	Each app receives only relevant roles; full scope off	billing-app: billing; ehr-simulator / patient-portal: nurse, clinician; hr-app: hr, it-support; fullScopeAllowed = false on all (E-AC-01)	**PASS**
3	Inspect Entra ID assignment model	Assignment required; one app role per user	Assignment required = true; Billing → Billing, Nurse → Nurse (E-AC-02)	**PASS**
4	Inspect MFA enforcement	MFA required for privileged / CDE access (policy 4.6)	Custom flow *browser-mfa-privileged* exists but no client uses it; realm uses default browser flow (E-AC-02)	**FAIL**
5	Inspect lockout and password policy	Lockout ≤ 10 attempts; 12+ chars; history 4 (policy 4.5)	bruteForceProtected = false; length(10); passwordHistory(3) (E-AC-02)	**FAIL**
6	Request last completed access review	Signed certification within 6 months	None available — procedure CAN-PRC-AC-002 not yet run (inquiry)	**FAIL**

Conclusion: design **Effective** for authorization; operating **Partially effective** because authentication hardening and periodic review are missing.

LOG-01 Security event logging, alerting and log review

#	Test performed	Expected	Actual (evidence)	Result
1	Inspect alert rules and routing	Rules for high-risk events, routed to security	7 activity-log rules enabled, routed to action group ag-can-secops (email) (E-LOG-01)	**PASS**
2	Inspect 30-day alert history	Alerts fire when events occur	50 alerts across 6 rules, incl. the Oct 8 incident (NSG change, key listing) and SSH brute force (E-LOG-01)	**PASS**
3	Inspect central log retention	12 months, 3 months online (PCI 10.5.1)	No Log Analytics workspace or Activity Log export since 2026-10-13; native retention 90 days only (E-LOG-01)	**FAIL**
4	Request daily log review records	Documented review each business day (PCI 10.4.1)	Alerts were triaged during the Oct 8 incident, but no routine daily review record exists (inquiry)	**FAIL**

Conclusion: alerting operated **Effective**; overall control **Partially effective** due to retention and review gaps.

ENC-01 Encryption of data in transit

#	Test performed	Expected	Actual (evidence)	Result
1	Re-perform: deploy storage allowing HTTP (validate-only)	Blocked	DENIED by storage-secure-transfer (E-ENC-01)	**PASS**
2	Re-perform: deploy storage allowing TLS 1.0	Blocked	DENIED by storage-min-tls12 (E-ENC-01)	**PASS**
3	Control test: compliant HTTPS + TLS 1.2 storage	Allowed	Validation passed; nothing deployed (E-ENC-01)	**PASS**
4	Inspect identity provider transport	TLS for all connections	sslRequired = external; lab instance served over HTTP on localhost only (E-ENC-01)	**EXCEPTION**

Conclusion: **Effective with exception** (lab IdP must use TLS in production).

4. Findings and Gap Analysis

ID	Rating	Finding	Requirement	Expected state	Current state (gap)
F-01	**High**	MFA not enforced	HIPAA §164.312(d); PCI 8.4.2; policy 4.6	MFA required for privileged and CDE access	MFA flow defined but not bound to any client
F-02	**High**	Account lockout disabled	PCI 8.3.4; policy 4.5	Lock after ≤ 10 failures for ≥ 30 min	bruteForceProtected = false (failureFactor 30 unused)
F-03	**High**	No 12-month central log retention	HIPAA §164.312(b); PCI 10.5.1	12 months retained, 3 online	Central workspace removed; 90-day native retention
F-04	**Medium**	Password standard below PCI minimum	PCI 8.3.6, 8.3.7; policy 4.5	≥ 12 characters; history 4	length(10); passwordHistory(3)
F-05	**Medium**	No completed access review / daily log review records	HIPAA §164.308(a)(4)(ii)(C), §164.308(a)(1)(ii)(D); PCI 7.2.4, 10.4.1	Signed reviews on schedule	Procedures defined (Task 2) but not yet executed
F-06	**Low**	Identity provider over HTTP in lab	HIPAA §164.312(e)(1); PCI 4.2.1	TLS 1.2+ end to end	HTTP on localhost; sslRequired=external

*Rating: **High** = direct non-compliance with a required control protecting ePHI/CDE; **Medium** = partial compliance or missing evidence; **Low** = limited exposure or lab-only.*

Compliance coverage after testing

Requirement area	Tested items	Compliant	Gaps	Coverage
Authorization / least privilege (HIPAA §164.308(a)(4); PCI 7.2)	3	3	0	100%
Authentication (HIPAA §164.312(d); PCI 8.3–8.4)	3	0	3	0%
Periodic review (PCI 7.2.4, 10.4.1)	2	0	2	0%
Audit logging and alerting (HIPAA §164.312(b); PCI 10.2)	2	2	0	100%
Log retention (PCI 10.5.1)	1	0	1	0%
Transmission security (HIPAA §164.312(e); PCI 4.2.1)	4	3	1 (exception)	75%
Total	**15**	**8**	**7**	**53%**

5. Remediation Plan

Recommendations are prioritized by risk rating, then by effort. Each action has an owner, a target date and a measurable completion test so progress can be tracked objectively.

#	Ref	Recommendation	Owner	Target	Done when
1	F-01	Bind *browser-mfa-privileged* to billing-app, hr-app and admin console; require OTP for Security Analyst, IT Support, Billing roles	IAM Analyst	2026-11-06	Test login prompts for OTP; E-AC-02 shows flow bound
2	F-02	Enable brute-force detection: failureFactor 10, wait ≥ 30 min	IAM Analyst	2026-10-23	11th bad password locks account
3	F-03	Restore Activity Log + Keycloak event export to a log store with 12-month retention (cost approval needed)	Security Officer	2026-11-30	Oldest log ≥ 90 days online, archive to 12 months
4	F-04	Set password policy length(12), passwordHistory(4)	IAM Analyst	2026-10-23	Realm passwordPolicy shows new values
5	F-05	Run first quarterly access review (CAN-PRC-AC-002); start daily log-review checklist	IAM Analyst / Security Analyst	2026-12-15	Signed review pack; 10 consecutive daily records
6	F-06	Front Keycloak with TLS 1.2+ reverse proxy; sslRequired=all in production	IT Support	2027-01-31	HTTPS only; HTTP redirects

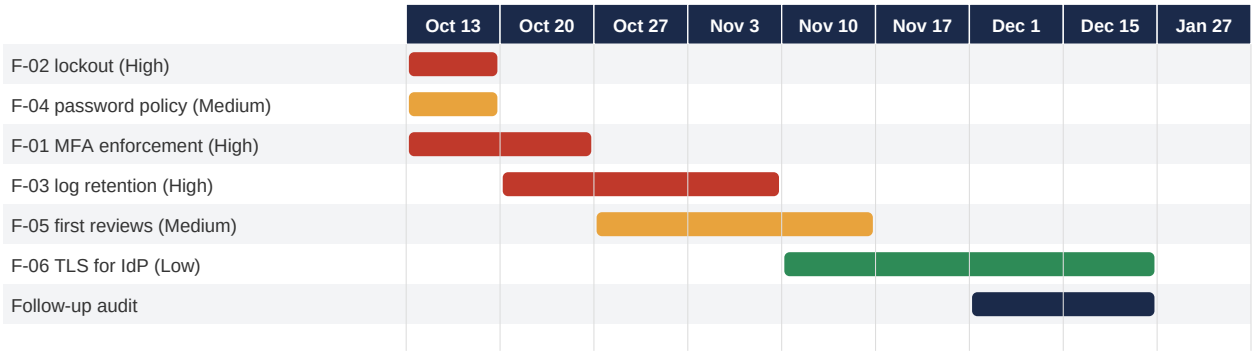

Figure 2. Remediation timeline (weeks from report).

Progress tracking

- Each finding is an entry in the **remediation tracker** (workbook `Care_Access_Navigator_Compliance1_Tracker.xlsx`, sheet *Remediation*) with owner, target date, percent complete and automatic RAG status: **Green** on track, **Amber** due within 7 days and < 75% complete, **Red** overdue.
- Owners update status weekly; the GRC Analyst reviews evidence before closing an item (closure requires the 'done when' test to pass and new evidence to be hashed into the index).
- The Compliance & Privacy Committee reviews open High findings monthly; anything Red for two consecutive months escalates to the Program Sponsor for risk acceptance or extra resources.
- A follow-up audit (January 2027) re-performs the failed tests and closes findings formally.

Appendix — Evidence Extracts

audit-evidence/E-AC-01_keycloak_users_roles.txt (SHA-256 2c94fabfceacd3d0…)

```
EVIDENCE E-AC-01  Keycloak realm 'care-access-navigator' — users and assigned realm roles
    (inspection)
Collected: 2026-10-13 17:47:42 UTC by GRC analyst (Akhila Chennamaneni) via kcadm.sh get
    (read-only)

  entra-id.ch.akhilarao@gmail.com                          (none)
  entra-id.test.billing@chakhilaraogmail.onmicrosoft.com   billing
  entra-id.test.nurse@chakhilaraogmail.onmicrosoft.com     nurse
  test.billing1                                            billing
  test.clinician1                                          clinician
  test.hr1                                                 hr
  test.itsupport1                                          it-support
  test.nurse1                                              nurse
  test.secanalyst1                                         security-analyst
  test.vendor1                                             vendor

Client role scopes (fullScopeAllowed=false limits which roles each app receives):
  billing-app      fullScope=False roles: billing
  ehr-simulator    fullScope=False roles: nurse, clinician
  patient-portal   fullScope=False roles: nurse, clinician
  hr-app           fullScope=False roles: hr, it-support

Identity-provider role mappers (Entra ID app role -> realm role):
  entra-role-billing           roles claim = Billing          -> billing  [sync FORCE]
  entra-role-clinician         roles claim = Clinician        -> clinician  [sync FORCE]
  entra-role-hr                roles claim = HR               -> hr  [sync FORCE]
  entra-role-it-support        roles claim = IT-Support       -> it-support  [sync FORCE]
  entra-role-nurse             roles claim = Nurse            -> nurse  [sync FORCE]
  entra-role-security-analyst  roles claim = Security-Analyst -> security-analyst  [sync FORCE]
  entra-role-vendor            roles claim = Vendor           -> vendor  [sync FORCE]
```

audit-evidence/E-AC-02_authn_settings_and_entra_assignments.txt (SHA-256 eec9ece839fcd292…)

```
EVIDENCE E-AC-02  Keycloak authentication settings + Entra ID application assignments (inspection)
Collected: 2026-10-13 17:48:11 UTC (read-only)

  bruteForceProtected      False
  failureFactor            30
  maxFailureWaitSeconds    900
  permanentLockout         False
  passwordPolicy           length(10) and upperCase(1) and lowerCase(1) and digits(1) and
    specialChars(1) and passwordHistory(3)
  otpPolicyType            totp
  browserFlow              browser
  sslRequired              external
  accessTokenLifespan      300
  ssoSessionIdleTimeout    1800
  eventsEnabled            True
  adminEventsEnabled       True

Authentication flows (custom):
  - browser (built-in)
  - browser-mfa-privileged (custom)

Clients bound to a non-default browser flow:
  (none)

Entra ID enterprise app 'care-access-navigator-keycloak-broker':
  appRoleAssignmentRequired = true
  Akhila Chennamaneni    -> Default Access
  Test Nurse             -> Nurse
  Test Billing           -> Billing
```

audit-evidence/E-LOG-01_alerting_and_log_retention.txt (SHA-256 0063a1a5ac8512a1…)

```
EVIDENCE E-LOG-01  Security event alerting configuration and alert history (inspection)
Collected: 2026-10-13 17:48:33 UTC (read-only, Azure Monitor + Alerts Management API)

Alert rules (Azure Monitor activity-log alerts) and notification target:
  al-nsg-rule-change         enabled=True  Firewall (NSG) rule created or modified
  al-nsg-rule-delete         enabled=True  Firewall (NSG) rule deleted
  al-role-assignment         enabled=True  New Azure RBAC role assignment (privilege change)
  al-policy-assignment-del   enabled=True  Governance policy assignment removed
  al-policy-exemption        enabled=True  Policy exemption created or changed
  al-storage-listkeys        enabled=True  Storage account keys retrieved
  al-defender-alert          enabled=True  Microsoft Defender for Cloud raised a security alert
  action group ag-can-secops -> secops-owner (email)

Alerts fired in the last 30 days (sample of control operation):
  al-defender-alert          fired  31 times  (first 2026-10-08 20:07 UTC)
  al-nsg-rule-change         fired   5 times  (first 2026-10-08 20:22 UTC)
  al-nsg-rule-delete         fired   3 times  (first 2026-10-08 20:32 UTC)
  al-role-assignment         fired   6 times  (first 2026-10-12 15:57 UTC)
  al-storage-listkeys        fired   4 times  (first 2026-10-08 20:22 UTC)
  sqr-ssh-bruteforce         fired   1 times  (first 2026-10-12 16:24 UTC)
  TOTAL alerts: 50

Central log repository status:
  Subscription Activity Log export to Log Analytics: 0 setting(s) (export removed 2026-10-13
    during lab teardown)
  Log Analytics workspaces: 0
  Native Activity Log retention: 90 days (platform default, not configurable)
```

audit-evidence/E-ENC-01_tls_enforcement.txt (SHA-256 2dda385fbcbb3290…)

```
EVIDENCE E-ENC-01  Encryption-in-transit enforcement (re-performance, validate-only — no resources
     created)
Collected: 2026-10-13 17:49:01 UTC

Policy assignment: CAN - Organization guardrails (SCP equivalent)   Default

Test 1  storage account allowing plain HTTP         -> DENIED by policy | rule:
    storage-secure-transfer
Test 2  storage account allowing TLS 1.0             -> DENIED by policy | rule: storage-min-tls12
Test 3  CONTROL: HTTPS-only, TLS 1.2 storage account -> ALLOWED (validation passed; nothing
    deployed)

Identity provider transport (Keycloak, lab host):
  sslRequired = external  (TLS required for non-local clients; localhost exempt)
  http://localhost:8080 -> HTTP 200 over plain HTTP (lab only)
```